

Eng 3.1. Secure Network Architecture

Task 1 - Introduction

Networking is one of the most critical components of a corporate environment but can often be overlooked from a security standpoint. A properly designed network permits not only internet usage and device communication but also redundancy, optimization, and security. In a well-designed network, if a switch goes down, then packets can be redistributed through another route with no loss in uptime. If a web server is compromised, it cannot traverse the network and access important information. A system administrator should be confident that their servers are secure if a random device joins a network, knowing that the device is segmented from the rest of the network and cannot access those systems.

Task 2 - Network Segmentation

The Need for Secure Segmentation: Subnets seem to solve all problems a network may face; why would we use another solution? To answer this question, let's consider a scenario where a client brings in their own device, a common practice known as **BYOD (Bring Your Own Device)**. The client's device was infected with a Remote Access Trojan (RAT) that will attempt to traverse the network the device is connected to and exfiltrate any sensitive information.

VLANs (Virtual LAN) are used to segment portions of a network at layer two and differentiate devices. VLANs are configured on a switch by adding a "tag" to a frame. The **802.1q** or **dot1q** tag will designate the VLAN that the traffic originated from.

Routing Between VLANs: Since they are segmented, they cannot communicate outside their tagged devices. Just as routers are used to communicate between traditional networks, routers can be used to route between VLANs. Before modern solutions were introduced, network engineers would physically connect a switch and router separately for each VLAN present. Nowadays, that problem is solved through the **ROAS (Router on a Stick)** design. VLANs are configured to

communicate with a router through a designated interface of a switch, known as a **switch port**. The connection between the switch and router is known as a **trunk**. VLANs are routed through the switch port, requiring only one trunk/connection between the switch and router, hence, "*on a stick*."

```
/ # ovs-vsctl show
87c2a3ee-5374-435a-81c2-e8aafa96e3b9
    Bridge br2
        datapath_type: netdev
        Port br2
            Interface br2
                type: internal
    Bridge br1
        datapath_type: netdev
        Port br1
            Interface br1
                type: internal
    Bridge br0
        datapath_type: netdev
        Port eth9
            tag: 30
            Interface eth9
        Port br0
            Interface br0
                type: internal
        Port eth13
            tag: 30
            Interface eth13
        Port eth14
            tag: 30
            Interface eth14
        Port eth15
            tag: 30
            Interface eth15
        Port eth2
            tag: 10
            Interface eth2
        Port eth8
            tag: 30
            Interface eth8
        Port eth3
            tag: 20
```

Answer the questions below:

| How many trunks are present in this configuration?

4 (bridges on the pictures)

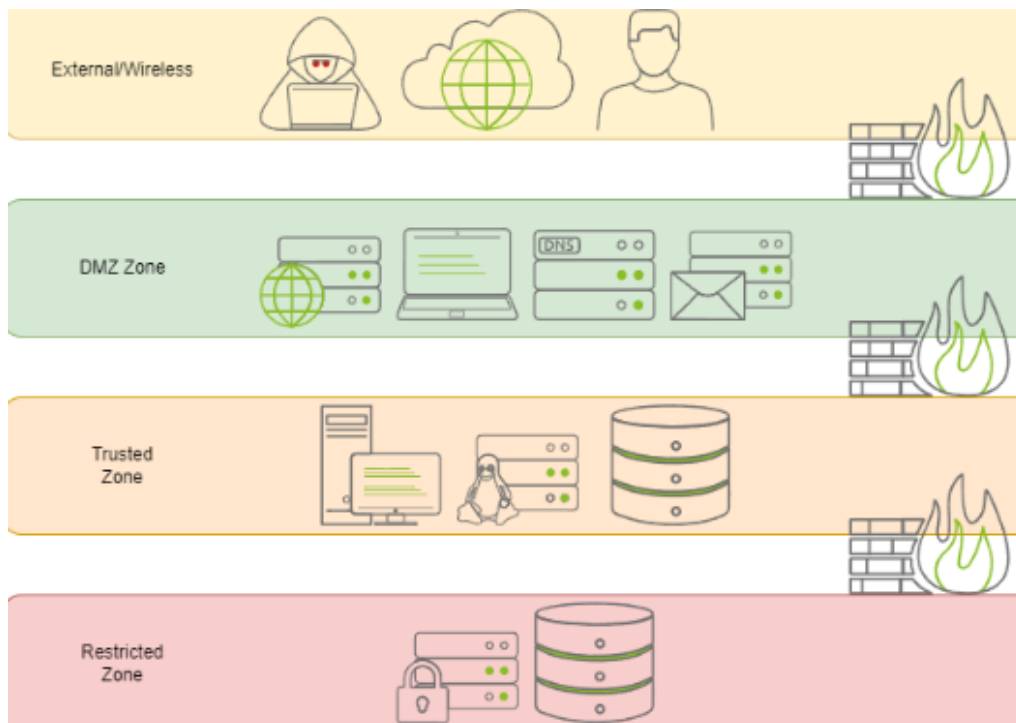
| What is the VLAN tag ID for interface eth12?

30 (check port eth12 on the picture)

Task 3 - Common Secure Network Architecture

Zone	Explanation	Examples
------	-------------	----------

External	All devices and entities outside of our network or asset control.	Devices connecting to a web server
DMZ (dem militarized zone)	Separates untrusted networks or devices from internal resources.	BYOD, remote users/guests, public servers
Trusted	Internal networks or devices. A device may be placed in the trusted zone if there is no confidential or sensitive information.	Workstations, B2B
Restricted	Any high-risk servers or databases.	Domain controllers, client information
Management	Any devices or services dedicated to network or other device management. This zone is less commonly seen and can be grouped with the audit zone.	Virtualization management, backup servers
Audit	Any devices or services dedicated to security or monitoring. This zone is less commonly seen and can be grouped with management.	SIEM, telemetry



Answer the questions below

From the above table, what zone would a user connecting to a public web server be in?

External

From the above table, what zone would a public web server be in?

DMZ

From the above table, what zone would a core domain controller be placed in?

Restricted

Task 4 - Network Security Policies and Controls

The most common standards of defining traffic filtering: **ACL(s) (Access Control List(s))**. An ACL is used as a loose standard to create a ruleset for different implementations and access control protocols. In this task, we will use ACLs within a router to decide whether to route or drop a packet based on the defined list. An ACL contains **ACE(s) (Access Control Entry)** or rules that define a list's profile based on pre-defined criteria (source address, destination address, etc.)

Answer the questions below

According to the corresponding ACL policy, will the first packet result in a drop or accept?

accept

▼ [Packet #1 \(Click to view\)](#)

```
Internet Protocol Version 4, Src: 10.10.212.209, Dst: 10.10.212.209
  Protocol: TCP (6)
  Header checksum: 0xbfdd [validation disabled]
  [Header checksum status: Unverified]
  Source: 10.10.212.209
  Destination: 10.10.212.209
  Transmission Control Protocol, Src Port: 35560, Dst Port: 22, Seq: 1578, Ack: 16
    Source Port: 35560
    Destination Port: 22
```

▼ [ACL Policy #1 \(Click to view\)](#)

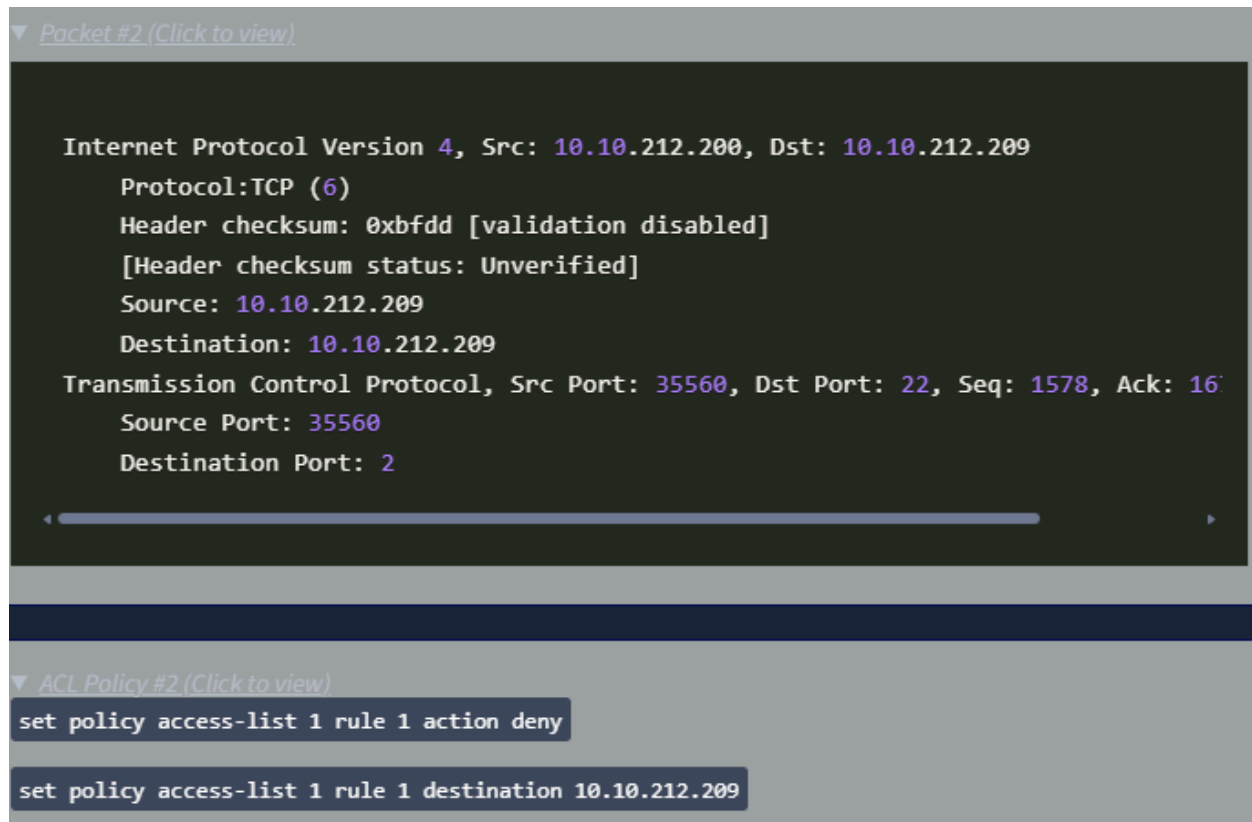
```
set policy access-list 1 rule 1 action permit
```

```
set policy access-list 1 rule 1 source 255.255.255.0
```

```
set policy access-list 1 rule 1 source 10.10.212.0/24
```

According to the corresponding ACL policy, will the second packet result in a drop or accept?

drop



Task 5 - Zone-Pair Policies and Filtering

Creating a Zone-Pair from Scratch: Now that you have an understanding of how to create a basic zone-pair policy, launch the static site attached to this task by pressing the green View **Site** button. Use the table below to fill in the blanks provided in the static site.

Source	Destination	Protocol	Action	Default Action
DMZ	LAN	HTTP	Accept	Drop
DMZ	WAN	-	-	Drop
LAN	DMZ	ICMP	Accept	Drop
WAN	DMZ	-	-	Drop

Common Name	Interface	Default Action
DMZ	eth0.10	Drop
LAN	eth0.20	Drop

WAN	eth0.30	Drop
-----	---------	------

Answer the questions below

What is the flag found after filling in all blanks on the static site?

THM{M05tly_53cure}

Time : 0min 24sec Remaining Attempts : (1/3)

set zone-policy zone	DMZ	default-action	drop
set zone-policy zone	DMZ	interface	Eth0.10
set zone-policy zone	LAN	default-action	drop
set zone-policy zone	LAN	interface	Eth0.20
set firewall name	dmz-lan	description	dmz-wan
set firewall name	dmz-lan	default-action	drop
set firewall name	dmz-lan	rule 100 action	accept
set firewall name	dmz-lan	rule 100 protocol	http

Task 6 - Validating Network Traffic

SSL/TLS Inspection: SSL/TLS inspection uses an **SSL proxy** to intercept protocols, including HTTP, POP3, SMTP, or other SSL/TLS encrypted traffic. Once intercepted, the proxy will decrypt the traffic and send it to be processed by a **UTM (Unified Threat Management)** platform. UTM solutions will employ deep SSL inspection, feeding the decrypted traffic from the proxy into other UTM services, including but not limited to web filters or **IPS (Intrusion Prevention System)**, to process the information. This solution may seem ideal, but what are the downsides? Some of you may have already noted that this requires an SSL proxy or **MitM (Man-in-the-Middle)**. Even if a firewall or vendor has already implemented the solution, it will still act as a MiTM between your devices and the outside world.

Answer the questions below

| Does SSL inspection require a man-in-the-middle proxy?

Y

| What platform processes data sent from an SSL proxy?

Unified Threat Management

Task 7 - Addressing Common Attacks

DHCP Snooping: Cisco defines **DHCP snooping** as "a security feature that acts like a firewall between untrusted hosts and trusted DHCP servers."

DHCP snooping was introduced to combat **rogue DHCP servers**; it will **validate** and **rate-limit** DHCP traffic as necessary. If a host is untrusted, its traffic will be filtered and rate-limited. Although DHCP is a layer three protocol, DHCP snooping operates on the switch at layer two. The switch will store untrusted hosts with leased IP addresses in a **DHCP Binding Database**. The database is used to validate traffic and can be used by other protocols, such as dynamic ARP inspection, which we will cover later in this task. We know how DHCP snooping will gather and store addresses, but how does it determine what to do with traffic? Below is a list of conditions the protocol will inspect to determine if a DHCP packet should be dropped.

- Any DHCP packet is received from outside of the network.

- The source MAC address and DHCP client hardware address do not match.
- A `DHCPRELEASE` or `DHCPDECLINE` packet is received on an untrusted interface that does not match an interface that the source address already has registered.
- A DHCP packet that includes a relay agent address that is not `0.0.0.0`

Dynamic ARP Inspection: Cisco defines **ARP inspection** as "a security feature that validates **A**ddress **R**esolution **P**rotocol (**ARP**) packets in a network." ARP inspection will **validate** and **rate-limit** ARP packets as necessary; if an ARP packet's MAC and IP address do not match, the protocol will intercept, log, and discard the packet. ARP inspection uses the DHCP binding database filled from DHCP snooping as its list of binding IP addresses.

Let's recap; the DHCP binding database provides the expected MAC and IP address pair of untrusted hosts; ARP inspection will compare the source IP address and MAC address to the binding pair; if they are mismatched, it will drop the packet.

Answer the questions below

| Where does DHCP snooping store leased IP addresses from untrusted hosts?

DHCP Binding Database

| Will a switch drop or accept a DHCPRELEASE packet?

Drop

| Does dynamic ARP inspection use the DHCP binding database?

Y

| Dynamic ARP inspection will match an IP address and what other packet detail?

MAC Address